ATIVIDADE PRÁTICA ORIENTADA (APO)

UNIPAR – UNIVERSIDADE PARANAENSE **Cianorte 2026**

Curso: Sistemas de Informação.

Disciplina: Legislação Aplicada a Tecnologia da Informação.

Atividade: Combinação de análise crítica de textos, interpretação de casos judiciais e aplicação prática de conhecimentos.

Temática: A proteção de dados em sistemas de informação.

Professor: Pedro Henrique Marangoni.

Aluno: Alexandre Felisberto de Aguilar. **RA: 09062004**

ETAPA 1 – ANÁLISE CRÍTICA E COMPARATIVA DE ARTIGOS

Introdução

A proteção de dados pessoais consolidou-se, nas últimas décadas, como um dos temas centrais do direito contemporâneo. O avanço exponencial das tecnologias de informação e a consequente intensificação do tratamento de dados pessoais por empresas privadas, plataformas digitais e pelo próprio Estado tornaram urgente a construção de um marco normativo robusto no Brasil. É nesse contexto que se inserem os dois artigos objeto desta análise: "A Lei Geral de Proteção de Dados Pessoais (Lei 13.709/2018) e a sua Principiologia", de autoria do Professor Guilherme Magalhães Martins, publicado na Revista dos Tribunais em maio de 2021, e "Direitos do Titular de Dados Pessoais no Ordenamento Jurídico Brasileiro", de Lucas Pacheco Vieira, publicado na mesma revista em dezembro de 2023. Ambos os textos têm a LGPD como eixo central, mas partem de perspectivas e recortes analíticos distintos, o que revela tanto convergências quanto divergências teóricas e metodológicas relevantes.

Teses Principais e Argumentos

Martins parte de uma perspectiva histórica e principiológica. Sua tese central é a de que os dados pessoais constituem verdadeiros direitos da personalidade, cuja proteção decorre diretamente da cláusula geral da dignidade da pessoa humana, prevista no artigo 1º, inciso III, da Constituição Federal de 1988. O autor sustenta que viver em uma sociedade da vigilância, expressão tomada de Stefano Rodotà, impõe aos titulares de dados uma condição de hipervulnerabilidade, pois estão inseridos em uma relação assimétrica que lhes subtrai o poder de autodeterminação informativa. Para Martins, a LGPD representa um esforço legislativo fundamental para reduzir essa assimetria, e a sua principiologia, expressa no artigo 6º da lei, é o núcleo normativo que orienta toda a atividade de tratamento de dados. O autor analisa detalhadamente os onze princípios da LGPD, sendo eles a boa-fé, a finalidade, a adequação, a necessidade, o livre acesso, a qualidade dos dados, a transparência, a segurança, a prevenção, a não discriminação e a responsabilização, demonstrando como cada um deles dialoga com o Código de Defesa do Consumidor, com o Código Civil e com o Marco Civil da Internet. Vieira, por sua vez, adota um enfoque mais dogmático e operacional. Sua tese principal é a de que os direitos subjetivos dos titulares de dados pessoais, especialmente os elencados no artigo 18 da LGPD, constituem pilares indispensáveis para a concretização do Direito da Proteção de Dados Pessoais como ramo jurídico autônomo. O autor percorre, de forma sistemática, cada um dos direitos dos titulares, como a confirmação da existência de tratamento, o acesso aos dados, a correção, a anonimização, o bloqueio, a eliminação, a portabilidade, a revogação do consentimento, a revisão de decisões automatizadas, a petição e a oposição, analisando sua estrutura normativa, os desafios práticos de implementação e os casos concretos em que já foram aplicados pela jurisprudência. Vieira confere especial atenção ao conceito de consentimento válido, dialogando criticamente com a doutrina de Bruno Bioni, que questiona se o paradigma do consentimento ainda é adequado ao contexto contemporâneo de tratamento massivo de dados.

Pontos de Convergência

Os dois autores convergem de modo expressivo em diversos aspectos. Em primeiro lugar, ambos reconhecem que a LGPD representa um avanço histórico e necessário para o ordenamento jurídico brasileiro, inserindo o país em um movimento global de regulação da proteção de dados pessoais que tem como referência o Regulamento Geral de Proteção de Dados da União Europeia. Em segundo lugar, tanto Martins quanto Vieira enxergam os dados pessoais como extensão da personalidade do indivíduo e, portanto, como objeto de tutela jurídica de natureza existencial e não meramente patrimonial, o que implica a prevalência desses direitos sobre interesses econômicos conflitantes. Um terceiro ponto de convergência importante é o reconhecimento de que a autodeterminação informativa constitui o fundamento ético e jurídico sobre o qual repousa toda a arquitetura da LGPD. Os dois autores afirmam que o titular de dados deve ter controle efetivo sobre suas informações pessoais, sendo o consentimento livre, informado e inequívoco a principal base que legitima o tratamento. Finalmente, ambos destacam a centralidade da Autoridade Nacional de Proteção de Dados para a efetividade da lei, sublinhando que sem uma entidade reguladora independente e com poder sancionatório real, os direitos dos titulares correm o risco de se tornarem letra morta.

Pontos de Divergência e Complementaridade

As divergências entre os dois textos são principalmente de ênfase, recorte e temporalidade. Martins escreve em 2021, logo após a entrada em vigor da LGPD, e seu foco é macronormativo: ele quer demonstrar que os princípios da lei não são meras diretrizes programáticas, mas normas jurídicas vinculantes que dialogam com todo o sistema jurídico brasileiro. Seu argumento é histórico e filosófico, ancorando a LGPD no processo evolutivo que vai da Declaração Universal dos Direitos Humanos de 1948 até o Regulamento Geral de Proteção de Dados de 2016. Vieira, escrevendo dois anos depois, já pode contar com jurisprudência e com uma doutrina mais consolidada, o que lhe permite uma análise mais operacional e detalhada de cada direito individualmente. Outra divergência relevante diz respeito ao tratamento do consentimento.

Para Martins, o consentimento é apresentado fundamentalmente como instrumento de autonomia do titular e como mecanismo de controle sobre o tratamento de dados, e sua abordagem é mais favorável ao paradigma do consentimento informado como eixo central do sistema. Vieira apresenta uma visão mais crítica e matizada, reconhecendo, com apoio em Bruno Bioni, que o paradigma do consentimento está sob pressão em razão da complexidade das cadeias de tratamento de dados na economia digital, onde os titulares frequentemente não possuem capacidade técnica nem poder de barganha para negociar os termos do tratamento. Há também uma diferença de escopo temático: Martins dedica parte significativa de seu artigo a analisar as alterações legislativas introduzidas pela Lei 13.853/2019 e a criação da ANPD, bem como a contextualizar o debate sobre proteção de dados em situações de emergência sanitária, como a pandemia de Covid-19. Vieira, embora reconheça a importância desses desenvolvimentos, concentra seu esforço analítico nos direitos dos titulares em si, conferindo maior profundidade à análise de institutos como a portabilidade de dados, a anonimização, o bloqueio e a eliminação, e trazendo exemplos jurisprudenciais concretos que enriquecem consideravelmente a compreensão prática da lei.

Considerações Finais da Etapa 1

Em síntese, os dois artigos se complementam de forma virtuosa. A leitura conjunta de Martins e Vieira oferece ao leitor uma compreensão abrangente da LGPD: Martins fornece o substrato filosófico, histórico e principiológico que fundamenta a lei e insere o Brasil no debate internacional sobre proteção de dados; Vieira oferece a análise sistemática e operacional dos direitos dos titulares, com atenção às dificuldades práticas de implementação e aos primeiros sinais de como a jurisprudência está interpretando e aplicando esse novo ramo do direito. Ambos os autores compartilham a convicção de que a LGPD é uma conquista civilizatória que precisa ser continuamente aprofundada, tanto pela doutrina quanto pela jurisprudência, para que a proteção dos dados pessoais dos cidadãos brasileiros se torne uma realidade efetiva e não apenas uma promessa normativa.

ETAPA 2 – INTERPRETAÇÃO E ANÁLISE DE ACÓRDÃOS

Acórdão 1 – Apelação Cível nº 1025549-54.2021.8.26.0100

Tribunal de Justiça do Estado de São Paulo – 30ª Câmara de Direito Privado

O primeiro acórdão foi proferido pela 30ª Câmara de Direito Privado do Tribunal de Justiça do Estado de São Paulo em 8 de março de 2023, nos autos da Apelação Cível nº 1025549-54.2021.8.26.0100, tendo como partes a Prudential do Brasil Seguros de Vida S/A, na condição de ré e apelante, e Pedro Henrique Camiloti, na condição de autor e apelado. O caso teve origem em um incidente de cibersegurança ocorrido em outubro de 2020, pelo qual dados pessoais do autor, que havia firmado uma apólice de seguro de vida com a ré em julho de 2018, foram acessados por terceiros não autorizados. As informações comprometidas incluíam nome, CPF, endereço, informações de saúde, bens, beneficiários e, em alguns casos, números de conta corrente. O autor ajuizou ação pleiteando indenização por danos morais e obrigação de fazer, consistente no fornecimento de informações detalhadas sobre o incidente. A sentença de primeiro grau julgou parcialmente procedente o pedido, condenando a ré a fornecer informações e a pagar R$ 10.000,00 a título de danos morais. Em segundo grau, o Tribunal, por maioria, deu parcial provimento ao recurso adesivo do autor para majorar a indenização para R$ 15.000,00, e, por votação unânime, deu parcial provimento ao recurso da ré apenas para afastar a obrigação de fazer.

Fundamentos Jurídicos: A decisão fundamentou-se em dois diplomas normativos principais: a Lei Geral de Proteção de Dados e o Código de Defesa do Consumidor. O Tribunal reconheceu a responsabilidade civil objetiva da seguradora com base nos artigos 42 a 45 da LGPD e no artigo 14 do CDC, rejeitando a tese da ré de que a responsabilidade seria subjetiva. O acórdão deixou assente que a falha na prestação dos serviços, caracterizada pelo acesso não autorizado aos dados, gera o dever de indenizar independentemente de culpa, pois decorre do risco inerente à atividade econômica de tratar dados pessoais de terceiros. Um aspecto de particular relevância jurídica foi o reconhecimento do dano moral in re ipsa, ou seja, aquele cuja existência se presume a partir do mero vazamento de dados pessoais sensíveis, dispensando a demonstração de efeitos deletérios concretos. Essa presunção decorreu do enquadramento das informações vazadas, especialmente as de saúde, no conceito legal de dado sensível previsto no artigo 5º, inciso II, da LGPD. Os dados sensíveis, em razão de seu potencial discriminatório, recebem proteção jurídica reforçada, o que justifica a presunção de dano quando violados. Quanto à obrigação de fazer, o Tribunal entendeu que os esclarecimentos prestados pela seguradora já eram suficientes, não havendo razão jurídica para mantê-la indefinidamente obrigada a revelar informações sobre investigação criminal em curso, o que poderia inclusive colidir com a presunção de inocência. A decisão foi tecnicamente precisa ao distinguir o dever de informação imediato, que a ré já havia cumprido ao notificar o titular do incidente nos termos do artigo 48 da LGPD, do dever de transparência processual contínua, que não encontra fundamento expresso na lei.

Termos Jurídicos Relevantes: Responsabilidade civil objetiva é a modalidade de responsabilidade em que o dever de indenizar independe da comprovação de culpa, bastando a demonstração do dano e do nexo causal. Dano moral in re ipsa é o dano moral cuja existência se presume da própria natureza do fato danoso, sem necessidade de prova de sofrimento concreto. Recurso adesivo é a modalidade de recurso interposta pela parte que não recorreu principalmente, vinculada ao recurso da parte contrária. Sucumbência é o encargo de arcar com as custas processuais e honorários advocatícios, atribuído à parte que perdeu a demanda.

Acórdão 2 – Recurso Inominado Cível nº 0034085-95.2021.8.16.0182

1ª Turma Recursal dos Juizados Especiais do Paraná

O segundo acórdão foi proferido pela 1ª Turma Recursal dos Juizados Especiais do Estado do Paraná em 17 de fevereiro de 2023, nos autos do Recurso Inominado Cível nº 0034085-95.2021.8.16.0182, tendo como partes Luciana dos Santos Falavinha, na condição de recorrente, e OI S.A. em Recuperação Judicial, na condição de recorrida. A relatora foi a Juíza Melissa de Azevedo Olivas. Neste caso, a autora alegou que a empresa de telecomunicações OI havia obtido seus dados pessoais de forma ilícita, provavelmente mediante compartilhamento indevido de informações que estavam em poder de sua operadora anterior, a Claro, com quem havia celebrado contrato pouco antes. A recorrente narrou ter sido contatada por representantes da OI oferecendo os mesmos serviços que ela acabara de contratar com a Claro, o que lhe causou a impressão de que seus dados haviam sido compartilhados de forma ilegal. O pedido era de indenização por danos morais em razão de suposto uso indevido de dados pessoais com base na LGPD. A sentença de primeiro grau julgou o pedido improcedente. A Turma Recursal, por unanimidade, negou provimento ao recurso, mantendo a improcedência.

Fundamentos Jurídicos: A decisão fundamentou-se na ausência de prova de vazamento de dados sensíveis protegidos pela LGPD. O acórdão estabeleceu uma distinção jurídica essencial: nem todo uso de dados pessoais configura violação à LGPD. O Tribunal reconheceu que as informações utilizadas pela OI, sendo o nome e o número de telefone da autora, eram dados de caráter público, acessíveis por simples pesquisa na internet, inclusive em cadastros empresariais da própria recorrente. A mera oferta de serviços por uma empresa concorrente, com base em informações públicas, não caracteriza o ilícito de tratamento indevido de dados pessoais para os fins da LGPD. O acórdão reafirmou que o dano moral indenizável pressupõe violação à dignidade, honra ou imagem do titular em intensidade que supere o que se poderia razoavelmente esperar que uma pessoa suportasse no convívio social. A mera abordagem comercial, ainda que incômoda, não atinge esse patamar.

O Tribunal também sublinhou que, mesmo em relações de consumo nas quais o ônus da prova pode ser invertido conforme o artigo 6º, inciso VIII do CDC, a parte autora não está completamente dispensada de demonstrar minimamente os fatos constitutivos de seu direito, especialmente a existência de um efetivo tratamento ilegal de dados sensíveis. Este segundo acórdão é particularmente relevante porque demonstra que a tutela da LGPD não é ilimitada. O legislador brasileiro não pretendeu proibir todo e qualquer uso de informações sobre terceiros, mas apenas o tratamento irregular de dados pessoais, especialmente os sensíveis. A decisão contribui para delimitar o campo de incidência da lei e evitar que qualquer contato comercial seja transformado em violação à proteção de dados, o que geraria insegurança jurídica generalizada para as atividades empresariais lícitas.

Termos Jurídicos Relevantes: Recurso inominado é a modalidade recursal típica do sistema dos Juizados Especiais Cíveis, equivalente à apelação no rito ordinário, cabível contra sentenças proferidas por Juizados Especiais. Inversão do ônus da prova é a prerrogativa do consumidor de ter em seu favor a presunção de veracidade de suas alegações, transferindo ao fornecedor o ônus de provar o contrário, quando presentes a hipossuficiência e a verossimilhança das alegações. Dado sensível é a categoria especial de dados pessoais que, por seu potencial discriminatório, recebe proteção jurídica reforçada pela LGPD, abrangendo origem racial, convicção religiosa, saúde, vida sexual, dados genéticos e biométricos.

Análise Comparativa dos Acórdãos

A leitura conjunta dos dois acórdãos revela a construção progressiva de uma jurisprudência coerente sobre a LGPD no Brasil. O primeiro caso consolida o entendimento de que o vazamento de dados sensíveis gera dano moral in re ipsa e que a responsabilidade do agente de tratamento é objetiva, não podendo ser afastada pela simples alegação de que terceiros invadiram o sistema. O segundo caso delimita os contornos da proteção, esclarecendo que a LGPD não criminaliza o uso de dados públicos ou o contato comercial ordinário, sendo necessária a comprovação do tratamento irregular de dados efetivamente sensíveis para configurar o ilícito.

Essa complementaridade jurisprudencial é fundamental para que a lei seja aplicada de forma equilibrada, sem que sua efetividade seja esvaziada nem que sua amplitude gere insegurança jurídica generalizada.

ETAPA 3 – CONSULTORIA DE PROTEÇÃO DE DADOS

Cenário Hipotético

Para a realização desta consultoria, adota-se como cenário hipotético uma startup de tecnologia em saúde, denominada HealthTech, que está desenvolvendo um aplicativo móvel e uma plataforma web para gerenciamento de prontuários eletrônicos e agendamento de consultas médicas. A aplicação coleta, armazena e processa dados altamente sensíveis de usuários, sendo pacientes e profissionais de saúde, incluindo histórico clínico, diagnósticos, medicamentos em uso, resultados de exames laboratoriais, dados biométricos como frequência cardíaca coletada por wearables integrados, além de dados cadastrais como nome, CPF, endereço, data de nascimento e informações financeiras para cobrança de planos e consultas. O sistema integra-se a laboratórios, farmácias, planos de saúde e prescritores, realizando compartilhamento de dados em tempo real. Dada a natureza dos dados tratados, a aplicação se enquadra diretamente nas hipóteses de dados pessoais sensíveis previstas no artigo 5º, inciso II, da LGPD, exigindo o mais elevado padrão de proteção legal e técnica.

Análise de Riscos e Vulnerabilidades

A seguir apresenta-se a matriz de riscos identificados no cenário, classificados por probabilidade e impacto potencial:

Matriz de Riscos e Vulnerabilidades

Ameaça e Vulnerabilidade	Probabilidade	Impacto	Nível de Risco
Acesso não autorizado ao banco de dados por SQL Injection ou NoSQL Injection	Alta	Crítico	CRÍTICO
Ausência de criptografia em dados em repouso e em trânsito	Alta	Crítico	CRÍTICO
Vazamento de dados por insider, sendo funcionário mal-intencionado ou negligente	Média	Crítico	ALTO
Falta de política de consentimento válido, livre, informado e inequívoco	Alta	Alto	ALTO
Retenção indefinida de dados além da finalidade declarada	Média	Alto	ALTO
Uso de dados para finalidade incompatível com a coletada, configurando desvio de finalidade	Média	Alto	ALTO
Ausência de Relatório de Impacto à Proteção de Dados	Média	Alto	ALTO
Ausência de canal de atendimento ao titular conforme artigo 18 da LGPD	Alta	Médio	MÉDIO
Ausência de Encarregado pelo Tratamento de Dados formalmente designado	Alta	Médio	MÉDIO
Transferência internacional de dados sem salvaguardas adequadas	Baixa	Alto	MÉDIO

Soluções e Ferramentas para Mitigação das Vulnerabilidades

Acesso Não Autorizado ao Banco de Dados

Esta é a vulnerabilidade de maior criticidade no cenário, dado que o banco de dados concentra todos os dados de saúde dos pacientes. As soluções recomendadas incluem o uso obrigatório de Prepared Statements e ORMs como Sequelize, Hibernate ou Prisma, que sanitizam automaticamente as entradas do usuário, eliminando a possibilidade de injeção de código malicioso. Recomenda-se ainda a adoção do princípio do menor privilégio, garantindo que cada módulo da aplicação acesse apenas os dados estritamente necessários para sua função, a implementação de Web Application Firewall com ferramentas como AWS WAF ou Cloudflare WAF, que monitoram e filtram requisições maliciosas antes de chegarem à aplicação, e a realização periódica de testes de penetração e análise estática de código com ferramentas como OWASP ZAP, Burp Suite e SonarQube. Complementarmente, recomenda-se a segmentação de rede com firewalls internos, de modo que o banco de dados nunca seja acessível diretamente pela internet, somente por camadas internas da aplicação devidamente autenticadas.

Ausência de Criptografia em Dados em Repouso e em Trânsito

A criptografia é uma exigência implícita dos princípios de segurança e prevenção da LGPD previstos no artigo 6º, incisos VII e VIII. Para o cenário em questão, recomenda-se a criptografia de todos os dados em trânsito utilizando TLS 1.3, garantindo que as comunicações entre cliente e servidor não possam ser interceptadas. Para os dados em repouso, recomenda-se o uso de AES-256, padrão adotado pelos principais provedores de nuvem como AWS, Google Cloud e Azure. Recomenda-se ainda o uso de gerenciadores de chaves criptográficas como AWS KMS ou HashiCorp Vault, para armazenamento seguro e rotação periódica das chaves, e a tokenização de dados altamente sensíveis como números de documentos e informações financeiras, substituindo os dados reais por tokens sem valor intrínseco fora do contexto do sistema.

Vazamento de Dados por Insider

O risco interno representado por funcionários mal-intencionados ou negligentes é frequentemente subestimado, mas constitui uma das principais causas de vazamento de dados sensíveis. As soluções recomendadas são a implementação de controle de acesso baseado em funções, conhecido como RBAC, garantindo que cada colaborador acesse apenas os dados necessários para o desempenho de suas atribuições, a adoção de ferramentas de DLP como Symantec DLP ou Microsoft Purview Information Protection, que monitoram e bloqueiam a transferência não autorizada de dados sensíveis para dispositivos externos ou contas pessoais, e o registro de todos os acessos e operações sobre dados pessoais sensíveis em logs de auditoria imutáveis, permitindo rastreabilidade completa. Recomenda-se também a realização de treinamentos periódicos em LGPD para todos os colaboradores conforme prevê o artigo 50 da lei, e a assinatura de Termos de Confidencialidade e Responsabilidade pelo Tratamento de Dados por todos os funcionários e prestadores de serviço com acesso a dados pessoais.

Falta de Política de Consentimento Válido

O consentimento é a principal base legal para o tratamento de dados de saúde em contextos não cobertos pelas hipóteses de dispensa do artigo 11 da LGPD. Para garantir a validade jurídica do consentimento obtido, recomenda-se a implementação de mecanismos de consentimento granular, que permitam ao titular aceitar ou recusar cada finalidade de tratamento de forma individual. Por exemplo, o usuário deve poder consentir com o tratamento de dados para agendamento de consultas sem necessariamente consentir com o compartilhamento com laboratórios parceiros. Recomenda-se ainda o desenvolvimento de políticas de privacidade redigidas em linguagem clara e acessível, evitando jargões técnicos que dificultem a compreensão pelo usuário médio, em conformidade com o princípio da transparência, o registro de logs de consentimento com carimbo de data e hora, e a implementação de funcionalidade fácil e gratuita para revogação do consentimento conforme exige o artigo 8º, parágrafo 5º, da LGPD. Ferramentas como OneTrust e Usercentrics podem ser utilizadas para automatizar esses processos.

Retenção Indefinida de Dados e Desvio de Finalidade

A LGPD determina em seu artigo 15 que o tratamento de dados pessoais deve ser encerrado quando atingida a finalidade ou quando os dados não forem mais necessários. Para adequação, recomenda-se a elaboração de uma política formal de ciclo de vida dos dados, conhecida como Data Lifecycle Management, que estabeleça prazos máximos de retenção para cada categoria de dado pessoal tratado, a implementação de rotinas automatizadas de eliminação segura dos dados cujos prazos de retenção tenham expirado, e a elaboração de um mapeamento completo de dados com manutenção de um Registro de Atividades de Tratamento, utilizando ferramentas como OneTrust Data Mapping ou TrustArc, que permitem identificar cada operação de tratamento, sua finalidade, base legal, agentes envolvidos e prazo de retenção. Recomenda-se ainda a revisão periódica dos contratos com operadores de dados para assegurar que o tratamento realizado em nome do controlador observa as mesmas finalidades e prazos declarados ao titular.

Ausência de Relatório de Impacto à Proteção de Dados

O artigo 38 da LGPD prevê que a ANPD pode determinar ao controlador a elaboração do Relatório de Impacto à Proteção de Dados Pessoais para operações de tratamento que possam gerar riscos às liberdades civis e aos direitos fundamentais. No cenário de uma HealthTech que trata dados de saúde em larga escala, a elaboração proativa desse relatório é indispensável. Recomenda-se conduzi-lo antes do início de qualquer nova operação de tratamento de dados sensíveis, avaliando sistematicamente os riscos à privacidade e os controles técnicos e organizacionais implementados para mitigá-los, além de mantê-lo atualizado e disponível para eventual requisição pela ANPD. Recomenda-se também a adoção da abordagem de Privacy by Design, que incorpora a proteção de dados ao processo de desenvolvimento de software desde as fases iniciais de arquitetura do sistema.

Ausência de Canal de Atendimento ao Titular e de Encarregado

O artigo 18 da LGPD assegura ao titular o direito de exercer uma série de prerrogativas perante o controlador, como a confirmação de tratamento, o acesso, a correção, a eliminação, a portabilidade e a revogação do consentimento.

Para cumprir esses requisitos, recomenda-se o desenvolvimento de um portal do titular integrado à plataforma, que permita o exercício digital de todos esses direitos de forma gratuita, fácil e tempestiva, a definição de um fluxo interno de resposta com prazos documentados, e a designação formal de um Encarregado pelo Tratamento de Dados, também chamado de DPO, nos termos do artigo 41 da LGPD, com a divulgação pública de seus dados de contato no site e no aplicativo.

Transferência Internacional de Dados sem Salvaguardas

Como a plataforma pode utilizar serviços de nuvem estrangeiros ou integrar-se a parceiros internacionais, o tratamento de dados com transferência para o exterior precisa observar as hipóteses do artigo 33 da LGPD. Recomenda-se a realização de um mapeamento de todos os fluxos transfronteiriços de dados, identificando cada serviço ou fornecedor que recebe dados de cidadãos brasileiros fora do território nacional, a celebração de cláusulas contratuais padrão com fornecedores estrangeiros que não estejam sediados em países com grau de proteção adequado reconhecido pela ANPD, e a preferência por provedores de nuvem que ofereçam regiões de dados localizadas no Brasil, como AWS São Paulo, Google Cloud São Paulo ou Azure Brasil Sul.

Recomendações Gerais de Governança em Proteção de Dados

Além das medidas técnicas detalhadas acima, a consultoria recomenda a adoção de um Programa de Governança em Privacidade e Proteção de Dados conforme previsto no artigo 50 da LGPD. Esse programa deve contemplar a elaboração e publicação de uma Política Geral de Privacidade e Proteção de Dados comunicando de forma transparente a todos os interessados como a empresa trata dados pessoais, a realização de auditorias periódicas de conformidade verificando se os processos, contratos, sistemas e documentações estão alinhados aos requisitos legais, e a implementação de um Plano de Resposta a Incidentes de Segurança, que defina os procedimentos a seguir em caso de violação de dados, incluindo o processo de notificação à ANPD e aos titulares afetados no prazo previsto pelo artigo 48 da LGPD.

Conclusão da Etapa 3

O cenário hipotético analisado revela que o desenvolvimento de um software que trata dados pessoais sensíveis exige uma abordagem integrada que combine medidas técnicas robustas de segurança da informação com um sólido programa de governança jurídica em conformidade com a LGPD. As vulnerabilidades identificadas, se não tratadas, expõem a empresa não apenas ao risco de sanções administrativas pela ANPD, que podem chegar a 2% do faturamento limitadas a R$ 50 milhões por infração nos termos do artigo 52 da LGPD, mas também a ações judiciais individuais e coletivas, ao dano reputacional e à perda de confiança dos usuários. A conformidade com a LGPD, portanto, não é apenas uma obrigação legal, mas uma vantagem competitiva e um compromisso ético com os titulares dos dados.

Conclusão Geral da APO

A realização deste trabalho proporcionou uma compreensão ampla e integrada sobre a proteção de dados pessoais no Brasil, articulando teoria, jurisprudência e aplicação prática de forma progressiva ao longo das três etapas.

Na Etapa 1, a análise comparativa dos artigos de Martins e Vieira evidenciou que a LGPD não é uma lei isolada, mas o resultado de um longo processo histórico de reconhecimento dos dados pessoais como direitos da personalidade, intimamente ligados à dignidade humana. Compreender a principiologia da lei é essencial para qualquer profissional de tecnologia da informação, pois são os princípios da finalidade, da necessidade, da transparência e da responsabilização que orientam como sistemas devem ser projetados, quais dados podem ser coletados e por quanto tempo podem ser mantidos. Ficou claro também que o consentimento, embora central no sistema da LGPD, não é absoluto: ele precisa ser genuinamente livre, informado e inequívoco para ter validade jurídica, o que impõe desafios reais ao desenvolvimento de interfaces e fluxos de coleta de dados em aplicações digitais.

Na Etapa 2, a análise dos dois acórdãos demonstrou como a LGPD está sendo efetivamente aplicada pelo Poder Judiciário brasileiro. O caso da Prudential deixou uma lição fundamental: empresas que tratam dados pessoais, especialmente dados sensíveis, assumem um risco inerente à sua atividade, e qualquer falha de segurança que permita o acesso não autorizado a essas informações gera responsabilidade civil objetiva, independentemente de culpa. O caso da OI, por sua vez, ensinou que a proteção da lei tem contornos bem definidos, pois ela não transforma qualquer uso de informação em ilícito, sendo necessária a comprovação do tratamento irregular de dados efetivamente sensíveis para que o dever de indenizar seja configurado. Essa leitura conjunta mostrou que conhecer a jurisprudência é tão importante quanto conhecer a lei em si, uma vez que é nos tribunais que os conceitos jurídicos ganham vida e se transformam em consequências concretas para empresas e cidadãos.

Na Etapa 3, a experiência de atuar como consultor de LGPD em um cenário de desenvolvimento de software revelou o quanto a proteção de dados é, na prática, uma responsabilidade compartilhada entre as áreas jurídica e técnica. Vulnerabilidades como a ausência de criptografia, a falta de controle de acesso e a inexistência de uma política de ciclo de vida dos dados não são apenas problemas de segurança da informação, mas também violações em potencial à LGPD, com consequências legais, financeiras e reputacionais severas. A abordagem de Privacy by Design ficou evidente como o caminho mais eficiente e responsável para o desenvolvimento de software na era da informação, justamente por incorporar a proteção de dados desde a concepção do sistema e não como uma correção posterior. Em síntese, este trabalho reforçou a convicção de que um profissional de tecnologia da informação que desconhece a LGPD está mal preparado para o mercado atual. A lei não representa um obstáculo ao desenvolvimento tecnológico, mas sim um conjunto de diretrizes que, quando incorporadas desde o início do ciclo de desenvolvimento, tornam os sistemas mais seguros, mais confiáveis e mais respeitosos com os direitos das pessoas que os utilizam.

REFERÊNCIAS

MARTINS, Guilherme Magalhães. A Lei Geral de Proteção de Dados Pessoais (Lei 13.709/2018) e a sua principiologia. Revista dos Tribunais, vol. 1027, ano 110, p. 203-243. São Paulo: Ed. RT, maio 2021.

VIEIRA, Lucas Pacheco. Direitos do titular de dados pessoais no ordenamento jurídico brasileiro. Revista dos Tribunais, vol. 1058, ano 112, p. 119-140. São Paulo: Ed. RT, dezembro 2023.

BRASIL. Lei nº 13.709, de 14 de agosto de 2018. Lei Geral de Proteção de Dados Pessoais. Brasília: Presidência da República, 2018.

BRASIL. Tribunal de Justiça do Estado de São Paulo. Apelação Cível nº 1025549-54.2021.8.26.0100. 30ª Câmara de Direito Privado. Relatora Designada: Desembargadora Maria Lúcia Pizzotti. Julgado em 8 de março de 2023.

BRASIL. Tribunal de Justiça do Estado do Paraná. Recurso Inominado Cível nº 0034085-95.2021.8.16.0182. 1ª Turma Recursal dos Juizados Especiais. Relatora: Juíza Melissa de Azevedo Olivas. Julgado em 17 de fevereiro de 2023.